Incidente de seguridad

4Geeks Academy

Introducción del incidente

Se detecto un ataque de Ransomware que comprometido a servidores críticos, este suceso ocurrió a causa de un logro de acceso mediante un ataque pishing que iba redirigido a un empleado consiguiendo la obtención de credenciales. Esto tomo como consecuencias:

- Cifrado de datos en servidores de desarrollo
- Base de datos de los clientes
- Interrupcion de servicios externos

Acciones de respuestas inmediatas

- **Aislamiento:** se hizo la desconexión de sistemas afectados de la red para evitas la propagación del malware.

- **Notificación:** se informo de inmediato a las autoridades pertinente y a los clientes afectados
- **Equipo de recuperación:** activación del equipo de respuesta a incidentes para lidera la contención

Análisis de vulnerabilidades detectadas

- **FTP con acceso anónimo:** se conecto sin credenciales, en listo contenido y descarga y subida de archivos desconocidos.
- **XML-RPC habilitado:** varios intentos de login, lo que provocaba el compriso de las cuentas y bypass de seguridad.
- **Exposición de archivos informativos**: Se identifico la exposición de “readme.html” junto con información visible del sistema.
- **WordPress expuesto:** estaba publicamente accesible, daba la posibilidad de escalacion de privilegios y compromisos de la red
- **Directory listing habilitado:** se monstruo una exposición directa de los archivos del servidor.
- **Permisos inseguros en ¨wp-config.php¨:** Archivo con permisos elevados sin restricción alguna.

Proceso de recuperación y restauración

- **Limpieza de sistema**
- Eliminación completa del ransomware de todos los servidores comprometidos.

- **Restauración de datos**

Recuperación exitosa de la información utilizando copias de seguridad (backups) verificadas.

- **Validación de seguridad**

Escaneo exhaustivo de vulnerabilidades antes de restablecer los servicios en linea.

Fortalecimiento y respuesta estratégica

Objetivo: Transición de una defensa reactiva a una infraestructura resiliente.

Pilar de seguridad	Acciones claves implementadas	Impacto del negocio
Infraestructura y red	Segmentación de subredes y cierre de puertos RDP expuestos	Define el ¨movimiento lateral¨de futuros ataques
Control de acceso	Desligue de MFA (multifactor) y reducción de privilegios de administrador	Blindaje de la identidad digital de los empleados
Continuidad y vigilancia	Restauración desde backups verificados y monitoreo 24/7 en tiempo real.	Garantiza disponibilidad y detección temprana de amenazas

Estrategia de prevención y resiliencia

Auditorias y blindaje técnica: ejecución semestral de pentesting y escaneo de vulnerabilidades para anticipar fallos antes de los atacantes.

- Mantenimiento riguroso de políticas de Hardening (fortalecimiento de sistemas) y parches de seguridad.

Capacitación del factor humano: programa obligatorio de concienciación en ciberseguridad y pishing para reducir el riego de error humano.

- Entrenamiento trimestrales basados en los vectores de ataque mas recientes detectados.

Gobernanza y mejora continua: actualización del Manual del SGI en un plazo no mayor a 2 semanas tras cualquier incidencia detectada.

- Institucionalización de sesiones de ¨lecciones aprendidas¨y reportes Post-mortem para la junta directiva.